

Unprotected Admin Functionality

Lab Information

Field	Value
Category	Access Control
Difficulty	Apprentice
Vulnerability	Broken Access Control

Summary

This lab demonstrates a classic **Broken Access Control** vulnerability where an administrative interface is exposed without proper server-side authorization. Although the administrator panel is not linked from the application's navigation, its location is disclosed through the `robots.txt` file, allowing unauthorized users to discover and access privileged functionality.

Objective

Access the hidden administrator panel and delete the user **carlos**.

Attack Scenario

The application attempts to hide the administrator interface by removing public links to it. However, the hidden endpoint is disclosed in the `robots.txt` file, which is publicly accessible.

Since the server does not verify whether the user has administrative privileges before granting access to the endpoint, any user who discovers the URL can perform administrative actions.

Steps to Reproduce

1. Open the application's `robots.txt` file.
2. Review the disallowed entries and identify the hidden administrator path.
3. Browse directly to the discovered administrator endpoint.
4. Confirm that the administrator panel is accessible without authentication or authorization.
5. Delete the user **carlos**.
6. Verify that the lab is solved.

Evidence

Discovered Resource

The `robots.txt` file exposed the location of the administrator interface.

Privileged Functionality

The administrator panel was accessible without any authorization checks, allowing privileged actions to be performed by an unauthorized user.

Security Impact

An attacker can access administrative functionality without possessing administrative privileges. This could lead to unauthorized user management, data modification, privilege abuse, or complete administrative compromise depending on the available functionality.

Root Cause

The application relied on obscurity rather than proper access control. Instead of validating user privileges on the server, the application assumed that hiding the administrator URL would prevent unauthorized access.

Remediation

- Enforce server-side authorization checks on every privileged endpoint.
- Never rely on hidden or unlinked URLs as a security mechanism.
- Avoid exposing sensitive endpoints through publicly accessible resources such as `robots.txt`.
- Apply the principle of least privilege to all administrative functionality.

Pentester's Notes

The first indicator was the presence of a `robots.txt` file. Since this file is commonly used to guide search engine crawlers—not to secure sensitive resources—it is often worth reviewing during reconnaissance. Discovering an administrator endpoint inside `robots.txt` suggested that the application relied on URL secrecy instead of proper authorization, making it a strong candidate for access control testing.

Key Takeaways

- Hidden endpoints are not secure endpoints.
- Every sensitive resource must perform server-side authorization checks.
- Files such as `robots.txt` should never be considered a security control.
- Security through obscurity is not a substitute for proper access control.